

ORION

PART 06

Security & Zero-Trust Architecture

Identity, authentication, authorization, encryption, threat defense

Technical Architecture Series • Beginner → Professional

How to use this volume

This document is one independent volume in the twelve-part ORION technical series. Beginners should read from the start; experienced readers can jump directly to the relevant architecture sections.

ORION is a secure communications, infrastructure-coordination, emergency-response, and decision-support architecture. High-impact weapons-control functionality is deliberately outside this design.

Security objective

Protect identity, devices, APIs, services, data, AI tools, and control paths as one architectural system.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Zero trust

No component is trusted merely because it is inside a network. Requests are evaluated using identity, device posture, context, resource, action, and policy.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Identity

Use strong authentication, short-lived credentials, device identity where appropriate, step-up authentication, and secure recovery.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Authorization

Least privilege, role-based access where useful, and attribute/context-based policies for sensitive operations. Temporary privileges should expire.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Encryption

TLS, service-to-service mTLS where appropriate, encryption at rest, managed keys, rotation, and secrets outside source code.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Threat modeling

Identify assets, trust boundaries, attackers, abuse cases, and failure modes before implementation.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

AI security

Defend against prompt injection, tool abuse, data poisoning, model supply-chain risk, sensitive-data leakage, and unauthorized agent actions.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Security controls

Policy-as-code, identity, segmentation, secrets management, audit logging, vulnerability management, backups, monitoring, and incident response.

Professional lens: define ownership, interfaces, trust boundaries, failure behavior, security controls, observability, and measurable success criteria before implementation.

Architecture Review Checklist

- Requirements and assumptions are explicit.
- Component ownership and boundaries are documented.
- Normal, degraded, and failure states are defined.
- Security and privacy are architectural requirements.
- Capacity and scaling assumptions are measurable.
- Logs, metrics, traces, and audit events cover critical flows.
- Dependencies have explicit contracts and failure behavior.
- Important decisions record alternatives and trade-offs.
- Testing covers expected behavior and controlled failures.
- Operational runbooks exist for important incidents.

Key Takeaways

Security & Zero-Trust Architecture should be implemented as a bounded layer of ORION, with explicit interfaces to the rest of the platform.

The goal is not maximum complexity. The goal is measurable resilience, security, maintainability, interoperability, and operational usefulness.

Glossary

- API — Application Programming Interface used for software-to-software communication.
- Edge — Computing placed near users or physical systems.
- Event — A record that something happened.
- Failover — Switching to a redundant component after failure.
- Idempotency — Repeating an operation does not create an unintended additional effect.
- NTN — Non-terrestrial network, commonly involving satellite infrastructure.
- Policy — A rule that determines what is allowed under stated conditions.
- RPO — Recovery Point Objective; acceptable data-loss window.
- RTO — Recovery Time Objective; target recovery time.
- Zero trust — Continuous verification instead of implicit trust based on network location.